

SECAUDIT 058 - current-codebase security sweep

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Field	Value
Audit ID	2026-09-18-058
Date	2026-09-18
Severity	HIGH (final) . Finding A was re-rated HIGH on second review: the credential leak was not a hostile-server hypothetical - the high-res download path is a Google Drive URL by design, so every high-res texture download sent the site key (possibly the full hub key) to Google. Finding B MEDIUM, C LOW, D (new) LOW.
Scope	Current dev tree through v0.7.723D, including CMS, multisite/federation/update surfaces, desktop clients, image ingress, backup/restore, credential stores, and current uncommitted SNAP SLAPPER/COLD SNAP work.
Method	Chokepoint review under SECAUDIT-PROCESS-PUBLIC.md; live source inspection; dangerous-sink inventory; 741-file PHP syntax pass; focused security regressions.
Status	CLOSED - fixes shipped in 0.7.724D / SUYB 0.7.44; second independent review complete (Claude, 2026-09-18) . SNAP SLAPPER carries Finding A's fix in its next build (source fixed; exe not yet rebuilt). Publication still gated on Sean per §8.
Reporter	Codex (first review), commissioned by Sean. Second review + fixes: Claude.
Related	053 (desktop suite), 055 (release package), 056 (high-bit release), 057 (Windows beta).
Disclosure	Fixes shipped and reviewed. Publication is Sean's call (see §8 - 055/056/057 are also unpublished pending a working COLD SNAP release).

1. Summary

The first pass found two real boundary failures and one audit-control defect. The most important is in the newly active Found Textures path: the catalogue can return an absolute media URL, and SNAP SLAPPER sends its Bearer credential to that URL. Because the compatibility fallback can be the broad hub credential, this can disclose a much more powerful key than a texture read requires. The second is a local availability failure in SUYB restore: a selected or cloud-downloaded ZIP is expanded wholesale before its contents or expansion cost are bounded. A crafted or damaged archive can consume the disk.

The focused regression run also exposed a stale security assertion for TYSWY. The code now intentionally accepts both tyswy and suyb, while the test still demands the literal single-type query. The implementation documents a defensible read-only superset relationship, so this is not filed as an authorization bypass; the red test is still a false signal that weakens the release gate.

No claim of full closure is made. The mandatory second adversarial review has not yet occurred, live code-execution controls have not all been exercised, and the large set of post-053 federation and desktop changes is still being traced.

2. Method and evidence

- Enumerated the audit ledger before assigning 058; 057 was the previous highest ID.
- Read the current audit standard and current source, not only diffs.
- Reviewed all six standard chokepoints: image ingress; config/profile ingestion;

desktop IPC/UI; update and restore; credentials at rest/in motion; desktop-to-server upload and URL fetches.

- Searched PHP/Python execution, deserialization, archive extraction, HTTP credential,

shell, and dynamic-SQL sinks.

- Ran `php -l` over all 741 tracked PHP files: **PASS**.
- Ran focused auth, client-IP, inbox-rate-limit, delivery-poison-row, RFC 9421, and

release-package regressions. All checks passed except the stale TYSWY scope assertion. The RFC 9421 test initially skipped because the CLI's OpenSSL extension and config are not enabled by default; it then passed all 11 checks when invoked explicitly with `php_openssl.dll` and `C:\php\extras\ssl\openssl.cnf` for that process only.

3. Findings

A. Server-supplied texture media URL receives the Bearer credential (MEDIUM -> HIGH) - CLOSED 0.7.724D

Evidence:

- `core/gyss-api.php:243-246` accepts an absolute `http://` or `https://` stored media path and returns it unchanged.
- `core/gyss-api.php:495` publishes that result as `thumb_url`.
- `tools/hub/found_textures.py:94` may fall back to the profile's broad hub key.
- `tools/hub/found_textures.py:237-241` sends the supplied key in `Authorization` to

whatever URL it is given.

- `tools/hub/slapper_qt/textures_dialog.py:61` passes the API-returned thumbnail URL and key directly into that fetch.

Failure mode: a compromised/misconfigured catalogue, imported absolute media path, or hostile compatible server can make SNAP SLAPPER send the raw site credential to a different origin. The `urllib` fallback also follows redirects while carrying ordinary request headers. With the current compatibility fallback, the exposed credential may be the full hub key rather than a read-only GYSS key.

Fail-closed fix: media fetches must never carry the API Bearer token; these are public image URLs. Additionally require the returned thumbnail/full URL to be HTTPS and same-origin with the configured catalogue unless the user explicitly chooses an external high-resolution link. API calls carrying credentials must refuse redirects or manually follow only a same-origin HTTPS redirect. Remove the hub-key fallback after discovery repair provisions a dedicated least-privilege key.

Sign-off tier: full sign-off (authentication boundary and credential model).

B. SUYB restore expands an unbounded ZIP before validating its cost (MEDIUM) - CLOSED SUYB 0.7.44

Evidence: `tools/smack-up-your-backup/restore_engine.py:60-67` creates a temporary directory and calls `ZipFile.extractall()` on a user-selected or cloud-downloaded archive. There is no entry-count limit, total uncompressed-size limit, per-entry limit, compression-ratio limit, or pre-extraction free-space check. The temporary directory is also not cleaned when extraction or later validation fails.

Failure mode: a hostile, corrupt, or accidentally pathological backup can exhaust the workstation's disk before SUYB inspects the recovery manifest, potentially disrupting other applications and leaving a large hidden temporary tree behind.

Fail-closed fix: inventory every member before extraction; reject unsafe names, links/special files, excessive member counts, excessive individual or total expanded size, and suspicious compression ratios; compare the bounded total with available disk space; stream members under a contained destination; always clean the temporary tree in a finally block.

Sign-off tier: single-reviewer close with adversarial ZIP regression tests; live restore verification remains required.

C. TYSWY scope regression is stale and leaves the security gate red (LOW) - CLOSED 0.7.724D

Evidence: `core/tyswy-api.php:175` and `:182` intentionally authorize `key_type IN ('tyswy', 'suyb')`, with the read-only superset rationale documented at `:156-162`. `tests/api-key-scope-regression.php:67` still searches for the obsolete literal `key_type = 'tyswy'`, producing the only failure in the focused security suite.

Failure mode: a permanently red security test trains maintainers to discount the gate and can conceal a new failure among known noise.

Fail-closed fix: assert the exact allowed set (tyswy, suyb), read-only route surface, and rejection of every other key type instead of matching an obsolete SQL substring.

Sign-off tier: single-reviewer close with the corrected test green.

4. Verified safe in this pass

- **PHP parse integrity:** all 741 tracked PHP files passed syntax validation.
- **Committed secret scan:** no private-key PEM blocks or recognizable OpenAI, GitHub,

AWS, Google, or Slack credential prefixes were found in the tracked tree or Git history. A broader current-tree assignment scan found only generated key material, placeholders, and test values - not a plaintext production API key. Untracked QA directories do contain encrypted credential-vault test artifacts (ciphertext plus local vault metadata), so they must remain excluded from packages and commits.

- **Central typed Bearer lookup:** `core/api-auth.php:126-188` scopes the database query

to endpoint-declared key types, rejects expired keys, and fails closed on lookup errors.

- **GYSS public catalogue query:** current scope tests confirm hub/SYBU compatibility is

restricted to the published-photo GET route rather than edit routes. This does not close Finding A, which concerns where the client transmits the resulting credential.

- **Client-IP trust regression:** passed.
- **Federation inbox shared-IP rate-limit and poison-row regressions:** passed.
- **RFC 9421 HTTP Message Signatures:** passed all 11 end-to-end checks with a real

ephemeral RSA keypair: valid signature accepted; body, digest, signature, key, age, covered-component, and target-URI tampering rejected; parser round-trip passed.

- **Release dev-directory exclusion/cleanup regression:** passed in full.
- **Skin package extraction paths inspected:** the CMS install and skin-registry paths

verify signatures before trusting executable packages and reject absolute, drive, NUL, and . . ZIP member names before extraction.

5. Chokepoint status

1. **Untrusted image ingress:** prior image-byte type gate remains present; external URL

origin/credential handling is OPEN under Finding A. Decoder containment still needs packaged live verification for this audit.

2. **Config / manifest / profile ingestion:** profile-to-key selection reviewed; broad

hub fallback is OPEN under Finding A. Remaining action-bearing URLs are still under review.

3. **Desktop webview / IPC:** no new eval/deserialization execution sink established in

the first pass; full current webview capability inventory remains OPEN.

4. **Update & restore:** signed executable skin/update controls were present on inspected paths; SUYB archive resource containment is OPEN under Finding B. Live updater and restore tests remain OPEN.

5. **Credential/token store:** at-rest controls were not found regressed in this pass; credential transmission is OPEN under Finding A.

6. **Desktop -> server upload / SSRF:** server upload parsers and arbitrary URL consumers remain in progress; Finding A is the first confirmed URL-boundary defect.

6. Closure checklist

- [x] Fix and regression-test Finding A at the media-fetch and credentialed-request boundaries. (0.7.724D; 8 tests.)
- [x] Fix and adversarially test Finding B, including cleanup on every failure path. (SUYB 0.7.44; 10 tests.)
- [x] Correct Finding C and restore an all-green security scope gate. (api-key-scope-regression.php ALL PASS.)
- [x] Fix Finding D (new, second review): SUYB vault tests contaminated by real Hub profiles. (SUYB suite 68/68.)
- [] Rebuild SNAP SLAPPER so Finding A's fix reaches the exe (Codex is mid-bump on slapper_qt/___init__.py; next build carries it).
- [] Rebuild SUYB 0.7.44 exe; watched live RESTORE (Sean).
- [] Packaged/live decoder, updater and desktop-credential tests - carried to the next audit; not part of the findings.
- [x] Second independent adversarial review (Claude, 2026-09-18, §7).
- [] Publish - Sean's decision (§8).

7. Second review - Claude, 2026-09-18

Independent read of the cited code on dev at v0.7.723D, plus Codex's uncommitted textures_dialog.py WIP in the main checkout. Every finding was reproduced against source before any fix was written.

A - CONFIRMED, severity raised to HIGH. Codex framed this as "a compromised or hostile server could...". It is the ordinary path. `found_textures.download()` takes `highres_download_url`, converts it to a Google Drive download URL (that is what `highres_fetch_url()` exists for) and calls `fetch_bytes(url, api_key)` - which put `Authorization: Bearer <key>` on it. Every high-res texture download therefore sent the site's key to `drive.google.com`; with the 0.7.723D compatibility fallback that key could be the full hub credential. `snap_api_safe_link()` only checks the scheme, so any http(s) host would have received it. Codex's WIP dialog does not change the credential path.

Fix (0.7.724D, tools/hub/found_textures.py): `fetch_bytes()` ignores the key entirely and refuses non-http(s) schemes (bytes are still gated by `snap_imgsafe`). `search()` - the single credentialed call - refuses plain http when a key is present, sends `allow_redirects=False` under requests, and uses a redirect-refusing opener under urllib (urllib re-sends headers on redirect). The hub-key fallback stays: it now only ever reaches the configured catalogue over https with no redirects, which is what 0.7.722D/723D intended. Tests: `tools/hub/tests/test_found_textures_credentials.py` - no Authorization on either HTTP stack for media, `file://` refused, `http+key` refused, 302 refused. SLAPPER suite 90/90.

B - CONFIRMED, MEDIUM stands. `restore_from_zip()` was `extractall()` with no checks and no cleanup; the cloud path funnels into it. Requires the operator's own cloud account or a bad local file, so MEDIUM. *Fix (SUYB 0.7.44, restore_engine.py):* `inventory_zip()` walks every member first - `is_safe_relative` names, no links/devices (Unix mode bits only; Windows-made zips carry none), ≤250 000 members, ≤8 GB per member, ≤200:1 expansion above 1 MB - then `extract_zip_bounded()` checks declared total + 512 MB against free space and streams each member

under `contained_local_path()`, aborting if a member yields more than it declared. Staging directory removed in finally. Tests: `tests/test_restore_zip_bounds.py` (10).

C - CONFIRMED. Reproduced: the only red in `api-key-scope-regression.php`. The IN ('tyswy', 'suyb') widening is documented and correct (a suyb key already receives the full SQL dump). *Fix*: the test now asserts exactly two occurrences of the exact allowed set and the absence of the old single-type SQL; a third key type turns it red. ALL PASS.

D - NEW (found while verifying B): SUYB vault-rollback tests contaminated by real Hub profiles (LOW). Running the whole SUYB suite showed two more reds Codex's focused run did not cover: `test_failed_enable_rolls_back_every_file_and_vault_state` and `test_failed_enable_restores_preexisting_stale_machine_key_state`. Cause: `profile_manager.list_profiles()` calls `sync_shared_profiles()`, which imports the operator's real Hub profiles (24 live sites, real API keys) into `PROFILES_DIR` - the test's temp directory. Two consequences: real keys were written to `%TEMP%` on every test run (deleted at teardown, but written), and the injected write-failure landed on a save path that swallows exceptions, so the rollback assertion never fired. Not a product defect - the sync is by design - a test-isolation defect. *Fix*: the test `setUp` patches `sync_shared_profiles` to a no-op. SUYB suite 68/68.

Codex's "verified safe" list: re-ran `api-key-scope-regression.php` and `tyswy-suyb-key-regression.php` (both pass after C). Did not re-run the RFC 9421 / inbox / client-IP suites - no code in their path changed in this audit.

Labels: A CLOSED · B CLOSED · C CLOSED · D CLOSED. No CONTAINED items. Residual work is delivery (exe rebuilds) and the live tests listed in §6, not open security findings.

8. Publication note

055, 056, 057 and now 058 are fixed and reviewed but unpublished because there is no working COLD SNAP release to point users at. That is a release-management gate, not a security one - nothing in these four audits is waiting on a fix. Sean decides when they go out. DUTY OF CARE: 058 A affects the shipped SNAP SLAPPER 0.8.05, so its disclosure should not wait on COLD SNAP.